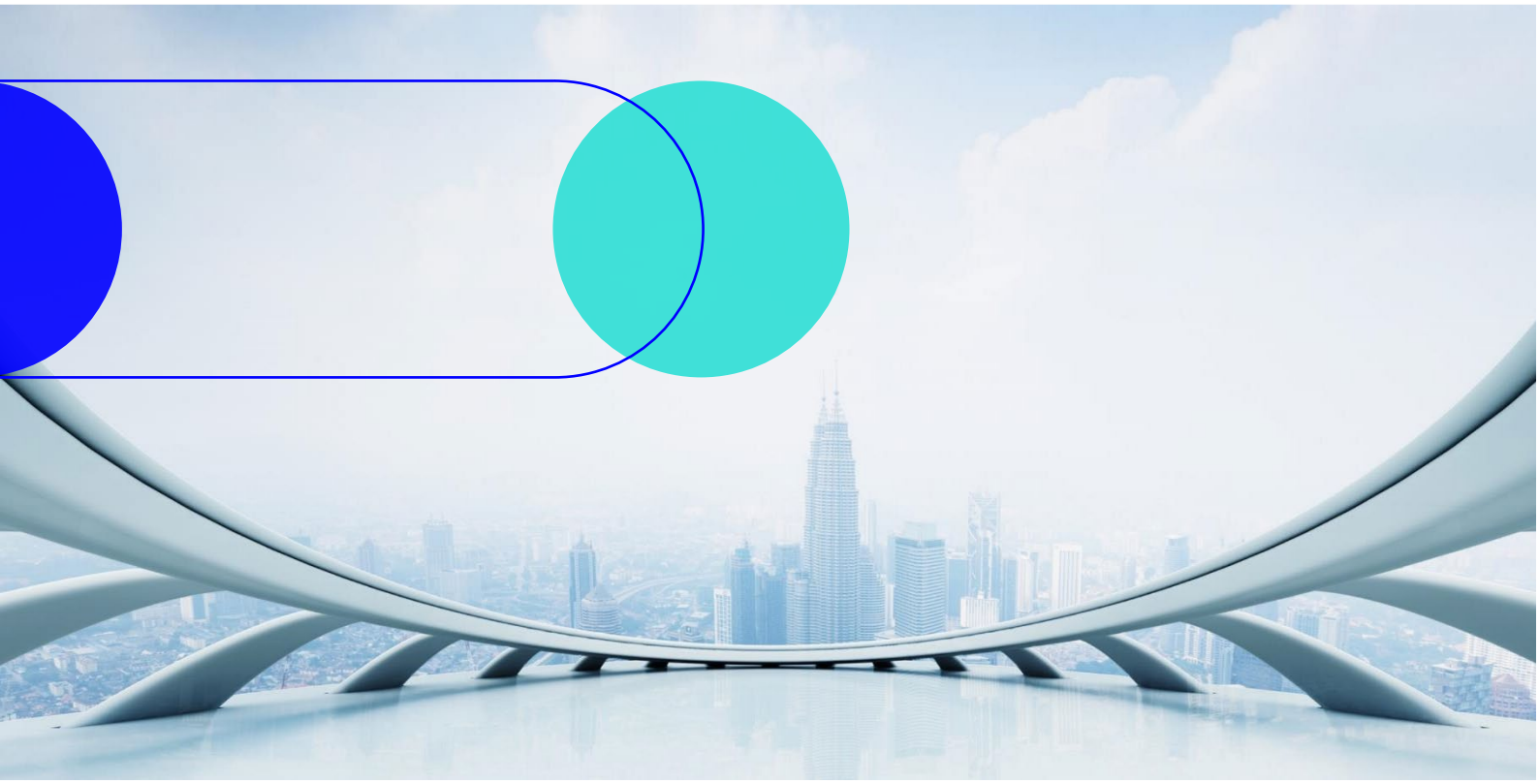
DOCAPOSTE

l'avenir devient plus simple



POLITIQUE GENERALE DE SECURITE DES SYSTEMES D'INFORMATION

Groupe DOCAPOSTE
Direction Sécurité Systèmes d'Information

C1 - Interne

POLITIQUE GENERALE DE SECURITE
Politique Générale de Sécurité des Systèmes d'Informations
SSI_PGSSI DOCAPOSTE 1.4.docx

CONTRÔLES	Prénom NOM	FONCTION	DATE
Rédigé par	William SAMPIETRO	DSSI	12/12/2018
Approuvé par	André VITAL	Directeur Infrastructures et Ingénierie partagée	02/04/2019
Validé par	Frédéric DUFAUX	Directeur Général adjoint	02/04/2019

Diffusion interne

Groupe
Personnels DOCAPOSTE

Diffusion externe

Groupe
Aucun

Page des évolutions

DATE	MODIFICATIONS	PAGES / CHAPITRE	Edition / Révision
20/06/2015	Version initiale	Tous	1.0
17/11/2015	Révision générale et approbation	Tous	1.1
11/12/2015	Version validée et diffusable		1.2
12/12/2018	Révision générale	Tous	1.3
30/08/2021	Révision générale	Tous	1.4

Classification
C1

Table des matières

1 INTRODUCTION 4
1.1 Objet et contexte 4
1.2 Périmètre 4
1.3 Enjeux de sécurité de l'information pour DOCAPOSTE 4
2 PRINCIPES GENERAUX 5
2.1 Maîtrise documentaire et évolution de la politique 5
2.2 Application et diffusion 5
3 PRINCIPES DE MISE EN ŒUVRE 5
4 RESPONSABILITES EN MATIERE DE SECURITE DE L'INFORMATION 6
4.1 Responsabilités des collaborateurs 6
4.2 Responsabilités des entités métier 6
4.3 Responsabilités des entités support 7
5 GOUVERNANCE DE LA SECURITE DES SI 7
6 CORPUS DOCUMENTAIRE DE REFERENCE 7
7 CONTROLE DE MISE EN ŒUVRE DE LA PGSSI 7
7.1 Contrôles permanents 7
7.2 Contrôles périodiques 8
7.3 Traitements des non-conformités 8

C1 - Interne

1 INTRODUCTION

1.1 Objet et contexte

Le présent document décrit les principes généraux de la politique de sécurité des systèmes d'information (PGSSI dans la suite des documents) de DOCAPOSTE.

La sécurité des systèmes d'information (SSI) participe activement au projet d'entreprise caractérisé dans la politique managériale énoncée par la direction générale et la feuille de route SSI annuelle.

Cette PGSSI a pour objectifs de préciser les enjeux de la SSI, définir les principes et les règles de mise en œuvre au sein des entités métier et supports, clarifier les responsabilités et organiser la gouvernance de la sécurité des systèmes d'information en tenant compte des évolutions structurelles de DOCAPOSTE. Elle est élaborée en cohérence avec le document de gouvernance de la SSI.

Tous les principes et règles sont précisés dans une hiérarchie de documents dont le présent document constitue le document fondateur.

1.2 Périmètre

Ce document porte sur la politique générale mise en place pour gérer la sécurité des systèmes d'informations opérés par DOCAPOSTE, notamment dans le cadre des prestations pour nos clients fournies par les entités métier (BU) et les entités support (DSI, etc.).

Cette PGSSI porte sur l'ensemble des systèmes d'informations de DOCAPOSTE :

- Les infrastructures d'hébergement et de support des systèmes d'informations (sites et ensemble des équipements de servitude)
- L'ensemble des matériels, systèmes d'exploitation, systèmes de gestion de base de données et des réseaux nécessaires au fonctionnement des applications métiers
- Les applications métiers qui procèdent au traitement de l'information
- Les données manipulées par les systèmes d'information
- Les personnels impliqués dans la conception, l'exploitation et l'utilisation des systèmes d'information (maîtrises d'ouvrage et d'œuvre, personnels d'administration et exploitation, de maintenance, utilisateurs, etc.).

1.3 Enjeux de sécurité de l'information pour DOCAPOSTE

Préserver la valeur de ses biens immatériels et matériels

L'information et les systèmes informatiques sont des ressources essentielles du fonctionnement des processus de production, de gestion et de pilotage, que DOCAPOSTE utilise pour satisfaire ses objectifs.

La préservation du patrimoine immatériel et matériel ainsi que des compétences qui permettent de les adapter et de les faire évoluer est un enjeu majeur pour DOCAPOSTE. Il est donc indispensable de consacrer les moyens nécessaires et de suivre l'effort consenti par DOCAPOSTE en matière de SSI.

Préserver son rôle de partenaire de confiance

Les enjeux de cette PGSSI relèvent de la volonté de DOCAPOSTE de renforcer la confiance auprès de ses clients, ses personnels et partenaires et d'accroître sa performance et d'améliorer sa gestion des risques.

L'implication des systèmes d'informations dans les processus de DOCAPOSTE est telle que tout dysfonctionnement important peut avoir des conséquences sur son fonctionnement ou son image et se traduire par une perte de confiance des clients et des partenaires.

L'adoption de règles communes est un gage de cohérence et d'efficacité pour assurer la sécurité des biens informationnels et matériels.

La SSI est une des conditions fondamentales pour préserver la confiance en DOCAPOSTE et conforter sa mission de protection des informations qui lui sont confiées.

Assurer la conformité de ses activités aux obligations légales et réglementaires

DOCAPOSTE doit s'assurer de la conformité de ses opérations aux obligations légales et réglementaires applicables et dans ce cadre, disposer de la capacité à fournir, en cas de nécessité, tous les éléments de preuves requis.

Son personnel doit respecter la législation et toute règlementation, règles de l'art, usages et droits d'autrui, codes de déontologie, applicables, comme par exemple la lutte contre le blanchiment et le terrorisme, la protection des données personnelles, la propriété intellectuelle, la fraude informatique, la cryptologie, la protection de la vie privée et du secret des correspondances, la diffusion d'information, la prospection commerciale, le secret bancaire et les codes de déontologie bancaires et financiers.

DOCAPOSTE doit mettre en place les procédures et outils permettant à chacun d'exercer ses responsabilités.

2 PRINCIPES GENERAUX

2.1 Maîtrise documentaire et évolution de la politique

Cette politique doit tenir compte des changements qui peuvent affecter les systèmes d'information et leurs environnements et doit être mise à jour, annuellement, en fonction :

- D'événements internes tels que la mise à jour des plans stratégiques de DOCAPOSTE, de son organisation ou de l'architecture de ses systèmes d'information
- D'événements externes tels que le changement de la législation et des règlements, la publication de nouvelles normes opposables
- De l'actualisation de la cartographie des risques des systèmes d'information
- L'apparition de nouvelles menaces
- L'utilisation de nouvelles technologies potentiellement sources de vulnérabilités
- Des améliorations identifiées lors des processus de contrôle et d'audit

L'évolution de cette politique est placée sous la responsabilité du DSSI DOCAPOSTE qui, après concertation des membres du CoSSI (Comité de la Sécurité des SI), propose au Directeur Infrastructures et Ingénierie Partagée les révisions et versions successives pour approbation avant validation par la Direction générale.

Ce document, et chacune de ses évolutions, est rendu accessible à l'ensemble du personnel de DOCAPOSTE.

2.2 Application et diffusion

La PGSSI s'applique à compter de sa publication :

- À l'ensemble de DOCAPOSTE (BU, entités supports et filiales).
- À l'ensemble du personnel autorisé à accéder aux ressources composant les systèmes d'information de DOCAPOSTE.
- Contractuellement, ou par le biais de conventions, aux clients, partenaires et fournisseurs dès lors qu'ils accèdent aux systèmes d'information de DOCAPOSTE ou que leur propre système d'information y est relié.

3 PRINCIPES DE MISE EN ŒUVRE

La mise en œuvre de cette PGSSI repose sur ces principes :

- Classifier les SI en regard des enjeux métiers afin d'identifier les biens essentiels, leurs « propriétaires » désignés et les « propriétaires des risques » liés à ces biens, les sécuriser au bon niveau. Les exigences sont appréhendées selon quatre critères : Disponibilité, Intégrité, Confidentialité et Preuve.
- Adopter un langage commun, respecter les normes et les bonnes pratiques publiées par les instances reconnues (ISO, AFNOR, ANSSI, etc.) afin de s'inscrire dans un cadre cohérent et universel, et d'être en mesure, le cas échéant, de répondre aux enjeux de certification.
- Organiser la veille et la surveillance afin de mesurer le niveau d'exposition de DOCAPOSTE aux différentes menaces, de détecter au plus tôt les comportements inhabituels, les attaques et les incidents de SSI, et de limiter leurs impacts dans le cadre d'une réponse coordonnée à l'échelle de DOCAPOSTE.
- Adopter un Système de Management de la Sécurité de l'Information (SMSI) sur un ensemble de processus documentés dans une logique d'amélioration continue et sur un dispositif de contrôles formel et accessible afin de pouvoir démontrer l'efficacité et la cohérence des actions menées.
- Prendre en compte les besoins de SSI en amont de chaque projet/prestation afin d'aligner les mesures de prévention et de protection sur les enjeux des métiers, optimiser les investissements, privilégier la prévention et augmenter l'efficacité des dispositifs.

- S'appuyer sur un dispositif de contrôles permanents formel et accessible, s'intégrant dans le dispositif de contrôle interne de DOCAPOSTE, afin de pouvoir démontrer l'efficacité et la cohérence des actions menées.
- Conserver et protéger les éléments permettant de reconstituer, a posteriori, les actions effectuées sur les informations sensibles afin de répondre au mieux aux exigences réglementaires, juridiques et de contrôle.

4 RESPONSABILITES EN MATIERE DE SECURITE DE L'INFORMATION

4.1 Responsabilités des collaborateurs

La mise en œuvre de la PGSSI relève de chaque collaborateur dans le respect des principes intangibles ci-dessous :

- Chaque responsable hiérarchique prend en compte les mesures relatives à la SSI dans les processus opérationnels. Il s'assure que les personnes qui accèdent aux informations sensibles ont fait l'objet d'un contrôle adéquat et ont été parfaitement informées de leurs responsabilités et des comportements à adopter dans les locaux et à chaque poste de travail. Il informe sa direction des incidents de sécurité rencontrés.
- Chaque collaborateur doit respecter les règles de sécurité édictées, ne pas contourner les dispositifs de sécurité et informer sa hiérarchie de tout incident ou anomalie constaté.
- Les personnels en charge du développement et du fonctionnement des ressources des systèmes d'information (équipes d'ingénierie logicielle, équipes de production informatique) mettent en œuvre les dispositifs de SSI dans le cadre fixé par la PGSSI et les maintiennent à niveau. Elles s'assurent que les nouvelles applications ou les évolutions des systèmes d'information ne génèrent pas de nouveaux risques. Plus généralement :
- Toute personne engageant DOCAPOSTE dans des contrats ou des conventions de service doit, en s'appuyant sur les experts requis (direction juridique, des achats, etc.), s'assurer de l'existence des clauses nécessaires à la prise en compte de la présente politique et que des procédures d'audit sont prévues.
- Tout porteur de changement et de contrôle doit s'assurer que les évolutions prévues ne sont pas de nature à fragiliser les dispositifs de sécurité mis en œuvre.

Chaque collaborateur peut, en tant que de besoin, s'appuyer sur le dispositif de pilotage mis en œuvre au niveau de DOCAPOSTE.

4.2 Responsabilités des entités métier

DOCAPOSTE veille, dans un souci de cohérence et d'efficacité, à ce que les mesures prises par l'ensemble de ses entités métier (BU) soient suffisantes pour assurer le respect des engagements vis-à-vis des clients, de son personnel et des partenaires.

Pour ce faire, le DSSI de DOCAPOSTE a mis en place une organisation (chaîne fonctionnelle de sécurité) pour animer et contrôler son déploiement selon le dispositif de gouvernance décrit dans le document « Gouvernance de la Sécurité des SI ». Dans le cadre de ce dispositif, chaque Direction de BU désigne un correspondant en sécurité des systèmes d'information (CSSI).

Les BU sont responsables de l'alignement des politiques de sécurité propres à chacune de leurs prestations (politiques opérationnelles de sécurité) avec les dispositions de la PGSSI (et des politiques générales de sécurité qui en dérivent) et peuvent les compléter s'ils le jugent opportun.

Chaque Direction de BU détermine le risque maximum tolérable des activités dont elle a la charge. Pour ce faire, il est de sa responsabilité, pour chacune de ses prestations, de faire inventorier et classifier ce qu'il est nécessaire de protéger et à quel niveau (cf. Principes de mises en œuvre : Classifier les SI).

Par ailleurs, en cas d'incident de sécurité des systèmes d'information avéré ou craint, chaque Direction de BU doit prévoir une information systématique de la chaîne fonctionnelle de sécurité, via leur CSSI, selon la gravité des incidents et s'articuler avec le dispositif de gestion de crise DOCAPOSTE.

C1 - Interne

4.3 Responsabilités des entités support

Les fonctions transverses, assurées par des entités dites support, participent à la mise en œuvre et au contrôle de la PGSSI. A ce titre :

- Les fonctions ressources humaines, en liaison avec les équipes de SSI, mettent en œuvre une politique active de sensibilisation et de formation. Elles définissent les critères, procédures et clauses permettant de sécuriser le processus de sélection, recrutement, mobilité et sortie d'emploi des personnels. Par ailleurs, elles contribuent à la politique de contrôle des accès aux systèmes d'information et aux installations en fournissant les éléments relatifs aux mouvements de personnel.
- Les fonctions juridiques tiennent compte dans leurs missions de supervision, de coordination, de veille et de conseil, des aspects législatifs, réglementaires, déontologiques et déclaratifs aux assurances ayant trait à la SSI. A ce titre, elles participent à la définition des procédures permettant de sécuriser les processus de contractualisation et coordonnent l'élaboration des déclarations soumises à la CNIL.
- La direction des achats définit les critères, procédures et clauses permettant de sécuriser le processus de sélection des fournisseurs et prestataires de services en s'assurant que les contrats et conventions de services touchant à des tâches jugées sensibles prévoient des dispositions particulières relatives à la protection des systèmes d'information de DOCAPOSTE.
- Les fonctions qualité et audit de la direction de la performance réalisent ou supervisent les audits relatifs à la SSI en s'appuyant sur les experts requis. Elles s'assurent de l'existence et de la pertinence des SMSI dans une logique d'amélioration continue.

5 GOUVERNANCE DE LA SECURITE DES SI

La gouvernance de la sécurité des systèmes d'information, décrite en détail dans le document intitulé « Gouvernance de la Sécurité des SI », repose sur

- Une organisation en chaînes hiérarchiques et fonctionnelles (correspondants sécurité des SI) animées par le DSSI DOCAPOSTE.
- Des instances de coordination et de pilotage.

6 CORPUS DOCUMENTAIRE DE REFERENCE

La PGSSI DOCAPOSTE se décline en un corpus documentaire de référence structuré en trois niveaux :

- **Niveau 1** Les documents fondateurs tels que cette PGSSI, la gouvernance de la SSI, la feuille de route SSI et les autres documents de même niveau tels que les chartes. Ils sont proposés par le DSSI DOCAPOSTE après consultation du CoSSI et validés par le Directeur Infrastructures et Ingénierie Partagée.
- **Niveau 2** Les documents de politiques générales relatives aux règles SSI à respecter (protection des équipements de travail, lutte contre les codes malveillants, sécurité des réseaux, etc.). Ils sont proposés par le DSSI DOCAPOSTE, après concertation du CoSSI, approuvés par le Directeur Infrastructures et Ingénierie Partagée et adressés aux entités de DOCAPOSTE pour application.
- **Niveau 3** Les documents de méthodes, guides pratiques, préconisations et autres mémos SSI. Ils favorisent un déploiement cohérent des dispositifs de sécurité et une approche économique. Ils émanent des acteurs de l'organisation SSI et sont validés en CoSSI.

Il est de la responsabilité du DSSI DOCAPOSTE de constituer ce cadre de référence DOCAPOSTE de la SSI.

Il est de la responsabilité des RSSI et des CSSI des entités métier et entités support de DOCAPOSTE de mettre en œuvre ce cadre dans leurs contextes respectifs en intégrant les compléments nécessaires (ex : Politiques Opérationnelles de Sécurité).

7 CONTROLE DE MISE EN ŒUVRE DE LA PGSSI

7.1 Contrôles permanents

Le dispositif de contrôle permanent a pour objectif de s'assurer que chaque processus obéit à une logique précise (objectifs clairs, points de contrôle, système d'enregistrement permanent, etc.). Les équipes d'ingénierie logicielle,

les équipes d'administration et exploitation des SI ainsi que les équipes en charge des dispositifs de sécurité fonctionnels et techniques sont les principaux acteurs de ce dispositif.

Les CSSI sont également des acteurs de ce dispositif en ce qui concerne les processus qui contribuent à la définition et au déploiement de cette PGSSI.

7.2 Contrôles périodiques

Les contrôles périodiques des politiques générales SSI relèvent de l'audit interne. Les échanges entre la fonction audit et la fonction SSI trouvent leurs limites dans le niveau d'indépendance des équipes.

Ils se traduisent par :

- Des réunions d'information à l'initiative du CoSSI pour que les équipes d'audit interne prennent connaissance des évolutions apportées aux référentiels de sécurité de DOCAPOSTE.
- Une information réciproque entre les équipes d'audit interne et le CoSSI sur les zones de risques identifiées.

7.3 Traitements des non-conformités

Les cas de non-conformité à la PGSSI et au corpus de politiques générales de sécurité (documents de niveau 2), quelle qu'en soit leur cause (impossibilité technique, arbitrage économique, etc.), doivent être signalés à la hiérarchie et au DSSI DOCAPOSTE, avec indication des mesures prises pour limiter les conséquences de ces situations ou éviter qu'elles ne se reproduisent.

C1 - Interne